

Manual 21 — Implementação controlada de segurança OT / ICS

Localização controlada pt-BR — desenvolvimento

****Ordem da série:**** 21

****Fonte inglesa vinculante:**** blob `e0a7095d14ce988e988077327ba1f01a8ffbde88`

****Linha de base pública principal:**** NIST SP 800-82 Rev. 3

****Limites de referência:**** série ISA/IEC 62443; avisos e mitigações ICS/OT da CISA

****Limite de controle:**** Tradução não oficial do projeto. Este guia não reproduz texto protegido de normas, não estabelece certificação, não substitui engenharia de segurança funcional e não transforma avisos em requisitos obrigatórios.

1. Objetivo, escopo e limites das fontes

Definir ambientes OT/ICS, instalações, processos, sistemas, redes, aplicações, dispositivos de campo, serviços de suporte e interfaces abrangidos. Registrar versões das fontes e distinguir orientação pública, normas protegidas, documentação de fornecedores e avisos temporais. Evidências: escopo aprovado, registro de fontes, exclusões, mapa de instalações/sistemas e monitoramento de mudanças.

2. Missão OT, segurança funcional e contexto do processo

Decisões de cibersegurança devem preservar operação segura e confiável do processo físico. Documentar funções críticas, dependências de segurança, restrições ambientais, disponibilidade, interrupção tolerável e situações que exigem revisão de engenharia ou segurança funcional. Evidências: criticidade, interfaces de risco, restrições operacionais e decisões aprovadas.

3. Governança, papéis e responsabilidade

Estabelecer responsabilidade entre direção, liderança da planta, engenharia de controle, operações, segurança funcional, cibersegurança, TI, segurança física, fornecedores e resposta a incidentes. Definir autoridade para aceitação de risco, acesso remoto, mudanças, indisponibilidade e ações de emergência. Evidências: estatuto, RACI, escalonamento, substitutos, reuniões e decisões.

4. Zonas, conduítes e segmentação de arquitetura

Modelar zonas de confiança, níveis de segurança ou agrupamentos equivalentes, conduítes, dispositivos de fronteira, centros de controle, sistemas de segurança, supervisão, estações de engenharia, redes de campo e interfaces corporativas. Limitar comunicações desnecessárias sem impedir fluxos requeridos. Evidências: diagramas, matrizes de fluxo, regras, exceções e testes.

5. Inventário e propriedade de ativos OT

Manter inventários autorizados de PLCs, DCS, HMIs, historiadores, estações de engenharia, componentes de segurança, gateways, dispositivos de rede, servidores, ativos virtuais, sem

fio, sensores, atuadores, aplicações e firmware. Registrar proprietário, local, função, criticidade, versão, identidade de rede, suporte e ciclo de vida. Reconciliar descoberta passiva, engenharia e manutenção.

6. Classificação de sistemas e componentes

Classificar conforme criticidade do processo, consequência de segurança, dependência operacional, exposição, recuperabilidade e impacto cibernético. Não reduzir consequências físicas ou perda de controle a uma única pontuação de negócio. Evidências: critérios, classificações, justificativas, dependências e gatilhos de reavaliação.

7. Avaliação de risco de cibersegurança OT

Avaliar cenários plausíveis considerando arquitetura, exposição, fraquezas conhecidas, capacidade do adversário, consequência no processo, segurança, ambiente, dificuldade de recuperação e salvaguardas existentes. Incluir dependências com TI, nuvem, fornecedores remotos e telecomunicações. Evidências: cenários, premissas, salvaguardas, risco residual, responsáveis e tratamentos.

8. Configuração segura e endurecimento

Definir baselines adequadas à tecnologia OT e às restrições operacionais. Desabilitar serviços desnecessários quando seguro, proteger administração, gerenciar credenciais padrão, interfaces removíveis e fontes de tempo, e documentar desvios necessários. Evidências: baselines, exportações, verificações, desvios e remediação.

9. Identidade, autenticação e controle de acesso

Aplicar menor privilégio e responsabilização individual quando tecnicamente viável, considerando limitações legadas e necessidades emergenciais. Separar privilégios de operador, engenheiro, administrador, serviço, fornecedor e aplicação. Proteger credenciais privilegiadas e registrar controles compensatórios quando o dispositivo não suportar autenticação forte.

10. Acesso remoto e manutenção privilegiada

Permitir conectividade remota somente por caminhos aprovados, monitorados e limitados no tempo. Exigir autorização explícita, intermediação segura, autenticação forte quando suportada, evidência de sessão e revogação rápida. Acesso emergencial deve ser controlado e revisado posteriormente. Evidências: arquitetura, registros, sessões, aprovações e testes de encerramento.

11. Segmentação de rede e proteção de fronteira

Controlar tráfego entre TI corporativa, redes OT, zonas de controle, sistemas relacionados à segurança, redes sem fio, fornecedores e serviços externos. Usar comunicações explicitamente permitidas quando viável e validar regras contra fluxos documentados. Evidências: firewalls/ACLs, baselines de fluxo, revisões, testes e exceções.

12. Protocolos industriais e segurança das comunicações

Inventariar protocolos industriais e de suporte, seus pressupostos de confiança, recursos de autenticação/criptografia, exposição e dependências operacionais. Aplicar variantes

seguras, gateways, filtragem, integridade ou segmentação compensatória quando recursos nativos forem limitados. Mudanças devem passar por validação de engenharia.

13. Arquitetura defensiva e salvaguardas em camadas

Projetar defesa em profundidade sobre acesso físico, fronteiras de rede, hosts, aplicações, identidades, fluxos de engenharia, monitoramento, backups, recuperação e procedimentos. Não depender de um único firewall, produto de endpoint ou suposto isolamento. Evidências: arquitetura em camadas, dependências, modos de falha e validação.

14. Monitoramento, logs e detecção de anomalias

Coletar telemetria de segurança e operação proporcional ao risco sem desestabilizar processos. Priorizar fronteiras, autenticação, estações de engenharia, servidores, acesso remoto, mudanças críticas e monitoramento passivo OT. Definir sincronização de tempo, retenção, triagem e escalonamento. Evidências: cobertura, saúde das fontes, detecções e investigações.

15. Gestão de vulnerabilidades e exposição

Identificar vulnerabilidades, configurações inseguras, serviços expostos, componentes sem suporte e avisos relevantes. Avaliar explorabilidade junto com consequência do processo, exposição, orientação do fornecedor, salvaguardas e janelas de manutenção. Não equiparar pontuação bruta de severidade ao risco OT. Evidências: achados, correlação, decisões, mitigações e retestes.

16. Gestão de patches e atualizações

Avaliar firmware, sistemas operacionais, aplicações e atualizações com informações do fornecedor, compatibilidade de engenharia, testes quando viáveis, rollback, janelas de manutenção e impacto no processo/segurança. Evitar mudanças não testadas em produção crítica. Evidências: inventários, aplicabilidade, testes, aprovações, implantações e risco adiado.

17. Controle de configuração e mudanças

Gerenciar mudanças de hardware, software, lógica, rede, firmware, contas, regras e arquitetura por avaliação e aprovação. Definir mudanças emergenciais e revisão posterior. Verificar backups e pontos de recuperação antes de mudanças materiais e monitorar drift não autorizado. Evidências: tickets, revisão de engenharia, testes, aprovações e configurações antes/depois.

18. Backups, restauração e engenharia de recuperação

Proteger cópias recuperáveis de lógica de controle, configurações, receitas, historiadores, imagens, documentação, licenças, chaves e demais materiais necessários. Manter cópias isoladas ou protegidas quando apropriado e testar restauração realisticamente. Evidências: inventários, configurações, testes, dependências e remediação.

19. Resposta a incidentes OT

Manter procedimentos OT para detecção, triagem, contenção, erradicação, recuperação, preservação de evidências, comunicações e escalonamento, integrados à segurança e

operações. Contenção que possa alterar o processo físico exige julgamento operacional autorizado. Evidências: planos, contatos, incidentes, exercícios, decisões e lições aprendidas.

20. Continuidade, modos degradados e operação manual

Definir como processos críticos permanecem seguros durante interrupção cibernética, perda de conectividade, supervisão, fornecedores ou serviços de engenharia. Documentar modos degradados e operação manual somente quando operacionalmente válidos e treinados. Evidências: planos, dependências, procedimentos, exercícios, prioridades de recuperação e ações corretivas.

21. Segurança de fornecedores e terceiros OT

Inventariar OEMs, integradores, manutenção, serviços gerenciados, nuvem, telecomunicações e fornecedores de software/componentes. Definir requisitos para acesso remoto, credenciais, atualizações, notificação de incidentes, suporte, subcontratados, evidências e encerramento. Evidências: contratos, avaliações, acessos, avisos, proveniência e remediação.

22. Engenharia segura e ciclo de vida do sistema

Integrar requisitos de cibersegurança desde projeto e aquisição até comissionamento, operação, modificação, manutenção e desativação. Definir revisões de projeto, critérios de aceitação, documentação, testes apropriados, expectativas de suporte e retirada segura. Evidências: requisitos, revisões, aceitação, planos de ciclo de vida e desativação.

23. Proteção física e ambiental

Coordenar cibersegurança com acesso a instalações, gabinetes, salas de controle, locais de campo, portas, energia, resfriamento, controles ambientais e adulteração. Aplicar proteções conforme consequência e condições reais. Evidências: acessos, inspeções, monitoramento ambiental, controles físicos, visitas e ações corretivas.

24. Mídias removíveis e dispositivos portáteis

Controlar laptops, estações portáteis, armazenamento removível, diagnóstico e mídias de fornecedores antes da conexão a OT. Definir autorização, varredura ou transferência controlada, propriedade, ferramentas aprovadas e tratamento de dados. Quando a varredura direta não for segura, usar processo intermediário controlado. Evidências: registros, aprovações, varreduras e exceções.

25. OT sem fio e habilitada por rádio

Inventariar Wi-Fi, celular, Bluetooth, rádio proprietário e sem fio industrial. Documentar cobertura, autenticação, criptografia, gestão de chaves, interferência/resiliência, detecção de dispositivos não autorizados e operação alternativa. Evidências: inventários, configurações, levantamentos, rotações de chaves, monitoramento e decisões de risco.

26. Coordenação e independência de sistemas de segurança

Tratar sistemas instrumentados de segurança e outras funções de proteção conforme requisitos de engenharia e segurança funcional. Avaliar dependências cibernéticas, comunicações, manutenção, falhas comuns e independência sem afirmar que cibersegurança substitui engenharia de segurança funcional. Evidências: diagramas, revisões, regras e testes coordenados.

27. Testes e validação de segurança

Planejar testes sem gerar risco inaceitável ao processo. Preferir ambientes representativos, técnicas passivas, métodos suportados pelo fornecedor, janelas controladas e rollback. Definir regras para avaliação de vulnerabilidade, testes de penetração, segmentação, recuperação e configuração. Evidências: planos, aprovações, resultados, achados, remediação e retestes.

28. Métricas, KRIs e arquitetura de evidências

Medir cobertura de inventário, ativos sem suporte, caminhos expostos, acesso remoto, monitoramento, tratamentos vencidos, mitigação, restauração, recorrência de incidentes e idade de exceções. Para cada salvaguarda registrar responsável, procedimento, frequência, evidência, método de teste, achados, remediação e reavaliação. Métricas não substituem julgamento de risco.

29. Governança de mapeamento entre frameworks

Mapear conceitos do NIST SP 800-82, referências ISA/IEC 62443, controles internos e obrigações apenas como auxílio rastreável. Não afirmar equivalência um-a-um nem herança de certificação. Registrar fonte/versão, justificativa, lacunas, ambiguidades, revisão quando aplicável e impacto de mudanças.

30. Treinamento e competência

Fornecer competência específica para operadores, engenheiros, administradores, respondedores, analistas, segurança funcional, compras e fornecedores. Cobrir acesso, mudanças, mídias removíveis, suporte remoto, reporte de anomalias, incidentes e consequências ciberfísicas. Evidências: trilhas por função, conclusão, exercícios, desempenho e ações corretivas.

31. Exceções e aceitação de risco

Documentar ativo/processo afetado, salvaguarda, justificativa técnica ou operacional, consequência, controles compensatórios, responsável, expiração, meta de remediação e reavaliação. Exceções de alta consequência exigem escrutínio proporcional e não devem permanecer por negligência administrativa. Evidências: registro, revisões, risco residual e encerramento.

32. Mudanças de fonte, localização, QA de artefatos e liberação

Monitorar mudanças do NIST, ISA/IEC 62443, práticas de avisos CISA, suporte de fornecedores e demais fontes adotadas. O inglês exato permanece congelado antes de es-

419 e pt-BR. Exigir paridade trilingue, geração reproduzível de seis binários DOCX/PDF, QA de renderização e acessibilidade, proveniência SHA-256, segurança de workflows, staging de bytes exatos, publicação do predecessor e reconciliação de catálogo/registo.

Limite de liberação controlada

Esta localização não constitui assessoria jurídica, certificação de produto, certificação de segurança funcional nem certificação ISA/IEC 62443. Avisos CISA e de fornecedores são insumos operacionais temporais. Pela regra canônica do repositório, um candidato sem erros ou pendências, com todas as portas objetivas aplicáveis verdes e o predecessor publicado, segue sob autorização permanente, salvo quando uma questão específica e genuinamente não determinística exigir julgamento especializado separado.